

Network Security Assessment

Target: sample_vulnerable_scan.xml

Scanned: 2026-08-14T23:04:31

Nmap invocation: `nmap -sT -sV -p- -oX sample\_vulnerable\_scan.xml 192.168.56.101`

Hosts up: 1

Rule-engine findings: critical: 6 · high: 7 · medium: 2

Analyst: llama-3.3-70b-versatile (Groq)

Prepared by: Faozan Mujtaba — Zynxis Agentic AI Internship, Week 6

This assessment covers an authorised scan only. Version-based findings are inferred from service banners and require verification against vendor advisories before being treated as confirmed vulnerabilities.

Executive Summary

The scanned host, metasploitable.local, presents a significant exposure with 22 open ports, indicating a potentially large attack surface. The most urgent issue is the presence of a backdoored vsftpd 2.3.4 on port 21, which is a critical vulnerability. Given the number of services exposed, it appears that this host may be intentionally configured as a public-facing server, but the presence of several critical vulnerabilities suggests that it may not be properly secured. Overall, the host's posture suggests a high level of risk, and immediate attention is required to address the identified vulnerabilities.

Risk Assessment by Host

The metasploitable.local host has a poor overall posture due to the large number of exposed services and critical vulnerabilities. The following table summarizes the key findings:

Severity	Finding	Port	Why it matters
CRITICAL	Outdated software: vsftpd 2.3.4	21	Backdoored version, allows unauthorized access
CRITICAL	Cleartext service exposed	23	Telnet transmits credentials and session data in cleartext
CRITICAL	Cleartext service exposed	513	rlogin is an unauthenticated legacy remote-access protocol
CRITICAL	Cleartext service exposed	514	rsh trusts the client's word for identity
CRITICAL	Database service reachable	3306	MySQL is listening on a network-reachable port, potentially exposing sensitive data
CRITICAL	Database service reachable	5432	PostgreSQL is listening on a network-reachable port, potentially exposing sensitive data
HIGH	Cleartext service exposed	21	FTP transmits credentials and data in cleartext
HIGH	Outdated software: OpenSSH 4.7p1	22	OpenSSH build predates 7.4, several user-enumeration and key-handling issues apply
HIGH	Cleartext service exposed	25	SMTP without enforced STARTTLS can expose mail in transit
HIGH	Outdated software: Apache httpd 2.2.8	80	Apache httpd 2.2 reached end of life in 2018 and receives no security fixes
HIGH	Remote administration surface: SMB	445	SMB grants broad control of the host and is a primary target for credential-stuffing and known-exploit attacks

Severity	Finding	Port	Why it matters
HIGH	Outdated software: ProFTPD 1.3.1	2121	ProFTPD 1.3.0-1.3.3 covers several remote-code-execution advisories
HIGH	Remote administration surface: VNC	5900	VNC grants broad control of the host and is a primary target for credential-stuffing and known-exploit attacks
MEDIUM	Large attack surface	-	22 open ports, unlikely to be applying least privilege
MEDIUM	HTTP served without HTTPS	80	Traffic to this host has no TLS option, so sessions and credentials travel in the clear

Suspicious Indicators

The presence of a backdoored vsftpd 2.3.4 on port 21 is a strong indicator of a potential compromise or misconfiguration. Additionally, the exposure of several cleartext services (telnet, rlogin, rsh, FTP, and SMTP) suggests a lack of attention to security best practices. The presence of a large number of open ports (22) also raises suspicions about the host's overall security posture.

Likely Vulnerabilities

The following vulnerability classes are implied by the detected software and versions:

- Remote code execution (REQUIRES VERIFICATION): vsftpd 2.3.4, ProFTPD 1.3.1
- Unauthorized access (CONFIRMED): vsftpd 2.3.4 (backdoored version)
- Credential exposure (CONFIRMED): telnet, rlogin, rsh, FTP, and SMTP (cleartext services)
- Data exposure (REQUIRES VERIFICATION): MySQL and PostgreSQL (database services reachable on network-reachable ports)
- User enumeration and key handling issues (REQUIRES VERIFICATION): OpenSSH 4.7p1

Prioritised Remediation

1. **Update vsftpd to a secure version** (metasploitable.local:21, medium effort): Replace the backdoored vsftpd 2.3.4 with a secure version to prevent unauthorized access. 2. **Disable cleartext services** (metasploitable.local:23, 513, 514, 21, 25, low effort): Disable telnet, rlogin, rsh, FTP, and SMTP services to prevent credential exposure. 3. **Restrict database services** (metasploitable.local:3306, 5432, medium effort): Restrict access to MySQL and PostgreSQL services to prevent data exposure. 4. **Update OpenSSH to a secure version** (metasploitable.local:22, medium effort): Update OpenSSH to a version that addresses user enumeration and key handling issues. 5. **Enable HTTPS** (metasploitable.local:80, low effort): Enable HTTPS to encrypt traffic to the host and prevent session and credential exposure. 6. **Restrict SMB and VNC services** (metasploitable.local:445, 5900, medium effort): Restrict access to SMB and VNC services to prevent unauthorized access. 7. **Update ProFTPD to a secure version** (metasploitable.local:2121, medium effort): Update ProFTPD to a version that addresses remote-code-execution vulnerabilities. 8. **Update Apache httpd to a secure version** (metasploitable.local:80, medium effort): Update Apache httpd to a version that receives security fixes and is not end-of-life.